

SABLE: Privacy-Preserving Biometric Authentication with Zero-Knowledge Proofs and Spatial Flash Liveness

Hugo O'Connor
Anuna Research
<https://anuna.io>

Abstract—Biometric authentication systems face a fundamental tension between usability and privacy: conventional approaches require centralized storage or cloud processing of irrevocable biometric data, creating high-value targets for breaches and surveillance. We present SABLE (Secure Attested Biometric Library for Edge), a system that performs biometric identity verification entirely through zero-knowledge proofs, ensuring that biometric data never leaves the user’s device. SABLE combines Halo2-based ZK circuits over quantized face embeddings with a novel spatial flash liveness protocol that detects presentation attacks by exploiting differential light reflectance on 3D facial geometry. The system operates fully offline via peer-to-peer communication and supports selective credential disclosure through BBS+ signatures. On commodity hardware (Apple Silicon), SABLE generates combined face-match and liveness proofs in approximately 250 ms with 2.08 KB proof size, and verifies them in under 2 ms — well within interactive latency requirements. To our knowledge, SABLE is the first open-source system to combine true zero-knowledge biometric proofs, transparent setup, offline peer-to-peer verification, and screen-based liveness detection without specialized hardware.

Index Terms—zero-knowledge proofs, biometric authentication, privacy, liveness detection, Halo2

I. INTRODUCTION

Biometric authentication offers strong identity assurance — a person’s face or fingerprint is difficult to forge and impossible to forget. Yet every major deployment model compromises on privacy. Centralized biometric databases create catastrophic breach risks: the 2015 U.S. Office of Personnel Management breach exposed 5.6 million fingerprint records, and India’s Aadhaar system has faced repeated data exposure incidents. Once biometric data is compromised, it cannot be revoked or reissued.

Cloud-based privacy solutions attempt to address this through multi-party computation (MPC), splitting biometric templates across servers so that no single party holds the complete data. While this reduces single-point-of-failure risk, it still requires always-on cloud infrastructure, trust in the operating parties, and cannot operate offline. Blockchain-based identity systems solve uniqueness through on-chain verification but require internet connectivity, incur gas fees, and do not inherently provide privacy-preserving biometric

matching. Hardware-dependent systems such as iris scanners achieve high accuracy but require proprietary capture devices, limiting deployment to controlled environments.

Contributions. We present SABLE, a system that resolves these trade-offs by combining several techniques into a coherent architecture:

- 1) **ZK biometric matching.** We construct Halo2 arithmetic circuits that prove a quantized face embedding matches an enrolled template within a Hamming distance threshold, without revealing the embedding. The circuit operates over 1024-byte quantized feature vectors using Poseidon hashing and Pedersen commitments.
- 2) **Spatial flash liveness.** We integrate a screen-based liveness detection protocol inspired by Tang et al. [1] into the ZK proof. A commit-reveal nonce scheme generates unpredictable split-screen color flashes; differential reflectance analysis distinguishes 3D faces from flat presentation attacks. The liveness evidence is quantized into 16-bit delta fingerprints and verified within the same Halo2 circuit.
- 3) **Offline selective disclosure.** SABLE supports optional BBS+ signed Verifiable Credentials, enabling users to prove predicates (e.g., “age ≥ 18 ”) without revealing underlying data. The Pedersen commitment anchors the biometric proof to the credential, and verification requires no internet connection.
- 4) **Practical performance.** On Apple Silicon, combined proof generation takes ~ 250 ms with a 2.08 KB proof, and verification completes in ~ 1.8 ms — all within a transparent-setup (no trusted ceremony) proof system.

II. SYSTEM ARCHITECTURE

SABLE comprises three principal roles: the *user* (prover), the *ZK engine*, and the *verifier*. An optional *identity issuer* (e.g., a government authority) may provide BBS+ signed Verifiable Credentials.

A. Enrollment

During enrollment, the user captures a face image via a standard smartphone camera. A feature extraction model

produces a 1024-dimensional floating-point embedding $\mathbf{e} \in \mathbb{R}^{1024}$. This embedding is quantized to $\mathbf{q} \in \{0, \dots, 255\}^{1024}$ (Section III-A), hashed with Poseidon into a field element $h = \text{Poseidon}(\mathbf{q})$, and committed via a Pedersen commitment $C = g^h \cdot h_r^s$ over BLS12-381, where s is a 256-bit random salt. The commitment C serves as the user’s “biometric public key” — it is stored by the verifier but reveals nothing about the underlying biometric.

B. Authentication

To authenticate, the user recaptures their face and undergoes the spatial flash liveness protocol (Section IV). The ZK engine then generates a Halo2 proof attesting that: (1) the fresh embedding matches the enrolled template within a Hamming distance threshold, (2) the liveness challenge was correctly completed with the HKDF-derived parameters, and (3) the proof is bound to a fresh challenge nonce. The proof exposes four public inputs — face-match result, threshold, liveness result, and a packed challenge digest — while no biometric data crosses the device boundary.

C. Selective Disclosure

If the user holds a BBS+ signed Verifiable Credential from an identity issuer, they may selectively disclose credential attributes alongside the biometric proof. The Pedersen commitment acts as the binding anchor between the biometric data and the credential. The Halo2 proof simultaneously covers biometric match and credential predicates in a single composite proof, so the verifier learns only the disclosed predicates (e.g., “age ≥ 18 ”) and the biometric match result.

D. Communication

SABLE operates peer-to-peer over NFC, BLE, or WiFi Direct. Session keys are established via X25519 ECDH and traffic is encrypted with ChaCha20-Poly1305 AEAD. No internet connection or central server is required for verification.

III. ZK FACE VERIFICATION

The core ZK circuit proves that a fresh biometric capture matches an enrolled template without revealing either. We describe each stage of the pipeline.

A. Embedding Quantization

Face embeddings from neural feature extractors are 1024-dimensional vectors of 64-bit floats, normalized to $[-1, 1]$. We quantize each component to an unsigned 8-bit integer:

$$q_i = \text{clamp}(\lfloor (e_i + 1.0) \times 127.5 \rfloor, 0, 255) \quad (1)$$

This maps $-1.0 \mapsto 0$, $0.0 \mapsto 128$, $1.0 \mapsto 255$, with a maximum per-dimension quantization error of $1/256 \approx 0.004$. The resulting 1024-byte vector is suitable for efficient circuit operations while preserving sufficient discriminative power for biometric matching.

TABLE I
HALO2 CIRCUIT CONFIGURATION

Parameter	Value
Circuit rows (2^k)	$2^{14} = 16,384$
Advice columns	4
Lookup advice columns	1
Fixed columns	1
Lookup bits	13
Public inputs	4 (face, threshold, liveness, digest)
Polynomial commitment	KZG (SHPLONK)
Transcript hash	Blake2b-256
Scalar field	BN254 (~ 254 bits)

B. Poseidon Commitment

The quantized embedding $\mathbf{q}$ is hashed using the Poseidon hash function [2], which is designed for efficient evaluation inside arithmetic circuits. We use Poseidon with width $t = 9$, rate $r = 8$, $R_F = 8$ full rounds, and $R_P = 56$ partial rounds over the BN254 scalar field. The output field element $h = \text{Poseidon}(\mathbf{q})$ is then used in a Pedersen commitment $C = g^h \cdot h_r^s$ over BLS12-381.

C. Hamming Distance Circuit

Rather than computing Euclidean distance (which requires expensive field multiplications), we measure similarity via Hamming distance over the byte-level representations. Given probe bytes $\mathbf{p}$ and reference bytes $\mathbf{r}$, the circuit computes:

$$d_H(\mathbf{p}, \mathbf{r}) = \sum_{i=1}^{8192} (p_i \oplus r_i) \quad (2)$$

where each byte is expanded to 8 bits. The XOR and popcount operations are implemented using lookup tables (with 2^{13} lookup entries, $k = 14$), making this far more efficient than field arithmetic over floats.

D. Threshold Check

The circuit enforces $d_H(\mathbf{p}, \mathbf{r}) \leq \tau$ where τ is a configurable threshold. The default configuration uses a 50% similarity threshold:

$$\tau = 8192 \times (1 - 0.5) = 4096 \text{ bits}$$

The comparison is performed via 254-bit decomposition and range checks. Stricter (60% similarity, $\tau = 3276$) and relaxed (40%, $\tau = 4915$) configurations are also supported.

E. Circuit Parameters

The complete face verification circuit uses Halo2 with the SHPLONK (SHared PLONKish) polynomial commitment scheme over BN254. Table I summarizes the circuit configuration.

IV. SPATIAL FLASH LIVENESS PROTOCOL

Presentation attacks — where an adversary holds up a photo, video, or screen displaying the victim’s face — are a well-known threat to camera-based biometric systems. SABLE integrates a software-only liveness detection protocol based on controlled-illumination reflectance analysis, inspired by Tang et al. [1], and extends it with ZK proof integration and a cryptographic commit-reveal scheme.

A. Commit-Reveal Nonce Scheme

To prevent either party from predicting or manipulating the flash pattern:

- 1) The client generates a 32-byte (256-bit) nonce n_c and sends its commitment $H(n_c)$ (SHA-256) to the server.
- 2) The server generates its own 32-byte nonce n_s and reveals it.
- 3) The client reveals n_c ; the server verifies $H(n_c)$.
- 4) Both parties derive the color pattern deterministically: $\text{colors} = \text{HKDF-SHA256}(n_c || n_s)$.

The challenge expires after 30 seconds and is single-use (consumed on first attempt), preventing replay attacks.

B. Split-Screen Color Flash

The derived HKDF output determines 6 RGB color values across 3 rounds, with each round displaying a *different* color on the upper and lower halves of the screen. Colors are subject to:

- **Photosensitive safety clamping** per WCAG 2.3.1, with luminance constrained to 40–100%.
- **Minimum angular distance** between paired colors, ensuring distinguishable differential reflectance.

C. 3D Geometry Detection

A real 3D face reflects split-screen illumination differently in the forehead region versus the chin region due to facial geometry and surface normals. A flat photo or screen reflects both colors identically. For each round, the system captures how the upper and lower face regions respond to the different colors and computes per-region delta vectors (the change in RGB pixel values from baseline). Spatial differentiation is confirmed when the cosine similarity between upper and lower delta vectors falls below a threshold.

D. Delta Fingerprint Quantization

Per-region color responses are quantized into compact 16-bit delta fingerprints encoding the essential reflectance characteristics:

$$\underbrace{\text{order}}_{3\text{ b}} \mid \underbrace{\text{mid_ratio}}_{4\text{ b}} \mid \underbrace{\text{min_ratio}}_{4\text{ b}} \mid \underbrace{\text{magnitude}}_{5\text{ b}} \quad (3)$$

- **Order** (3 bits): Channel ordering (e.g., $R \geq G \geq B = 0$).
- **Mid ratio** (4 bits): Ratio of the middle channel to the maximum.
- **Min ratio** (4 bits): Ratio of the minimum channel to the maximum.
- **Magnitude** (5 bits): Overall brightness response (0–31).

TABLE II
PERFORMANCE RESULTS (APPLE SILICON, RELEASE MODE)

Operation	Target	Achieved
Key generation + first proof	–	~900 ms
Proof generation (face + liveness)	≤ 1000 ms	~250 ms
Verification	≤ 50 ms	~1.8 ms
Proof size	≤ 10 KB	2.08 KB
Spatial flash challenge	–	3 rounds, ~1 s

E. ZK Proof of Liveness

The delta fingerprints are fed into the Halo2 circuit alongside the face-match check, producing a single composite proof. The circuit verifies three conditions per round:

- 1) **Color match:** $d_H(\text{fingerprint}_{\text{actual}}, \text{fingerprint}_{\text{expected}}) \leq \tau_c$ (the observed reflectance matches the expected pattern).
- 2) **Spatial differentiation:** $d_H(\text{fingerprint}_{\text{upper}}, \text{fingerprint}_{\text{lower}}) \geq \tau_s$ (upper and lower face regions responded differently, indicating 3D geometry).
- 3) **Magnitude check:** $\text{magnitude} \geq m_{\min}$ (adequate flash response was detected, ruling out non-reflective spoofs).

The verifier learns only pass/fail — no raw reflectance data, pixel values, or camera frames are exposed.

F. Verifiable Challenge Digest

A naïve circuit design would load the expected fingerprints ($\text{fp}_0, \dots, \text{fp}_5$) and thresholds ($\tau_c, \tau_s, m_{\min}$) as private witnesses. However, this allows a malicious prover to substitute arbitrary values — for example, setting $\tau_c = 16$ (accepting any fingerprint) — while still producing a valid proof. The verifier would have no way to detect this substitution.

To close this gap, we pack all nine liveness parameters into a single field element exposed as a *public input*. The packing format (LSB-first) is:

$$\delta = \sum_{i=0}^5 \text{fp}_i \cdot 2^{16i} + \tau_c \cdot 2^{96} + \tau_s \cdot 2^{104} + m_{\min} \cdot 2^{112} \quad (4)$$

The total payload is 120 bits (6×16 -bit fingerprints + 3×8 -bit thresholds), which fits comfortably in the 254-bit BN254 scalar field without overflow or hashing.

Crucially, the circuit loads each threshold and expected-fingerprint witness *exactly once* and reuses the same assigned values for both the liveness checks and the digest packing. This ensures a prover cannot use one value in the checks and a different value in the digest. The verifier independently computes δ from the HKDF-derived nonces and checks it against the public input, cryptographically binding the proof to the correct challenge parameters.

V. PERFORMANCE EVALUATION

We evaluate SABLE on an Apple M-series processor (ARM64) in release mode. Table II presents the key metrics.

The initial key generation and proving key setup takes approximately 900 ms, but the proving key is cached after first

use, so subsequent proof generations complete in ~ 250 ms. This is well within the 1-second target for interactive authentication. Verification at 1.8 ms is effectively instantaneous from the user's perspective. The 2.08 KB proof size is suitable for transmission over constrained channels such as NFC or BLE.

The total end-to-end authentication time, including 3 rounds of spatial flash (~ 1 s), face capture, and proof generation, is approximately 1.5–2 seconds — comparable to conventional biometric unlock experiences.

The circuit uses $2^{14} = 16,384$ rows with 4 advice columns and KZG polynomial commitments. This is a moderate circuit size by Halo2 standards, and the performance benefits from the lookup-table-based Hamming distance computation rather than expensive field multiplications.

VI. SECURITY ANALYSIS

A. Cryptographic Security

SABLE targets 128-bit security. The Halo2 proof system operates over BN254 (~ 254 -bit scalar field) with KZG polynomial commitments, providing computational soundness under the discrete logarithm and pairing assumptions. Pedersen commitments over BLS12-381 (381-bit base field, embedding degree 12) are computationally hiding and binding under the discrete logarithm assumption. Poseidon hash provides collision resistance over finite fields with parameters chosen per the original security analysis [2].

The transparent setup of Halo2 eliminates the trusted ceremony required by systems such as Groth16, removing a significant trust assumption from the system.

B. Replay Protection

Several mechanisms prevent replay attacks:

- **Challenge TTL:** Each liveness challenge expires after 30 seconds and is consumed on first use.
- **Commit-reveal:** The client commits $H(n_c)$ before the server reveals n_s , preventing either party from choosing nonces to produce a known flash pattern.
- **HKDF derivation:** Color patterns are deterministic but unpredictable given the combined nonces, so pre-recorded responses cannot be reused.
- **Nonce binding:** The proof includes the challenge nonce, binding it to a specific authentication session.
- **Ephemeral sessions:** P2P channels use X25519 ECDH with fresh ephemeral keys.

C. Challenge Parameter Integrity

The challenge digest (Section IV-F) prevents a class of attacks where a malicious prover substitutes relaxed thresholds or arbitrary expected fingerprints while producing a cryptographically valid proof. Because the digest is a public input, the verifier independently computes the expected value from the HKDF-derived nonces and rejects proofs where the digest does not match. Furthermore, the circuit reuses the same witness cells for both the liveness checks and the digest computation, so there is no opportunity for the prover to use different values internally.

D. Presentation Attack Resistance

The spatial flash protocol raises the bar significantly beyond static attacks:

- **Photos:** A flat photo reflects split-screen colors identically across the surface, failing the spatial differentiation check.
- **Screen replay:** A screen displaying a face video also reflects illumination uniformly, as the display surface is flat.
- **Video manipulation:** The commit-reveal nonce scheme prevents an attacker from pre-computing the color sequence, as they cannot predict n_s before committing to n_c .

E. Honest Limitations

SABLE does not claim to defeat all presentation attacks:

- **3D masks:** A high-quality silicone or 3D-printed mask with realistic surface properties would reflect split-screen light similarly to a real face. Mitigation requires depth sensors or multi-spectral imaging, which SABLE explicitly avoids to maintain hardware independence.
- **Real-time video manipulation:** Sophisticated real-time deepfake systems that can modulate camera input in response to observed flash patterns are not addressed.
- **Quantum computing:** BLS12-381 and BN254 are vulnerable to Shor's algorithm. Post-quantum migration (e.g., lattice-based commitments and proof systems) will be necessary as quantum computing matures.

VII. RELATED WORK

Screen flash liveness. Tang et al. [1] demonstrated that controlled screen illumination can distinguish 3D faces from 2D spoofs by analyzing differential light reflectance. SABLE builds on this approach, extending it with a cryptographic commit-reveal nonce scheme for unpredictability, compact 16-bit delta fingerprint quantization for efficiency, and integration into a ZK proof circuit so that raw reflectance data is never exposed to the verifier.

ZK proof systems. Groth16 [3] provides succinct SNARK proofs but requires a per-circuit trusted setup ceremony. PLONK [4] introduced universal and updatable structured reference strings, reducing the trust burden. Halo2 [5] achieves transparent setup (no ceremony) with recursive proof composition, using KZG polynomial commitments. SABLE uses Halo2 with the SHPLONK variant for its combination of transparent setup, practical prover performance, and mature tooling.

Privacy-preserving biometrics. Homomorphic encryption approaches [6], [7] allow biometric matching on encrypted data but incur high computational costs and typically require server-side processing. MPC-based systems [8] split biometric templates across parties but require online coordination. FaceChain [9] and similar blockchain-based systems provide decentralized identity but rely on on-chain verification. Most recently, Mao et al. [11] proposed ZABA, which combines Pedersen vector commitments with multimodal cancelable

biometrics (fingerprint, face, iris) for e-health authentication, achieving ~ 78 ms proving time. However, ZABA requires an online authentication server, does not address liveness detection, and its Sigma-style proofs incur ~ 140 ms verification time — roughly $78\times$ slower than SABLE’s 1.8 ms succinct Halo2 verification. Lai et al. [10] proposed BioZero, which verifies biometric Euclidean distance on Ethereum via Groth16 proofs over homomorphic Pedersen commitments. Groth16 yields compact ~ 256 -byte proofs, but requires a per-circuit trusted setup ceremony; moreover, on-chain verification incurs gas costs and an internet dependency on every authentication. BioZero also lacks liveness detection. SABLE differs from all of the above by performing matching entirely in a ZK circuit on the user’s device with transparent setup, requiring no server-side computation, internet connectivity, or multi-party coordination, while additionally integrating liveness detection into the proof.

Anonymous credentials. BBS+ signatures [12], [13] enable selective disclosure of credential attributes. The W3C Verifiable Credentials standard provides an interoperability framework. SABLE’s architecture supports BBS+ credentials anchored to the biometric Pedersen commitment, enabling composite proofs that simultaneously attest biometric match and credential predicates.

VIII. CONCLUSION

We have presented SABLE, a privacy-preserving biometric authentication system that combines Halo2 zero-knowledge proofs, Pedersen commitments, Poseidon hashing, and a spatial flash liveness protocol into a practical, offline-capable architecture. SABLE generates combined face-match and liveness proofs in ~ 250 ms with 2.08 KB proof size, operates peer-to-peer without internet or specialized hardware, and supports selective credential disclosure via BBS+ signatures. The spatial flash protocol provides meaningful resistance to photo and screen replay attacks through 3D geometry detection, while the commit-reveal nonce scheme prevents pattern manipulation.

SABLE is open-source under the Apache 2.0 license. Future work includes post-quantum migration, formal verification of circuit constraints, multi-spectral liveness detection, and real-device validation across diverse hardware and lighting conditions.

REFERENCES

- [1] S. Tang, X. Wang, X. Lv, T. X. Han, J. Keller, Z. He, M. Skubic, and S. Lao, “Real-time face verification with lightweight learned liveness detection using screen flash,” in *Proc. NDSS*, 2018.
- [2] L. Grassi, D. Khovratovich, C. Rechberger, A. Roy, and M. Schofnegger, “Poseidon: A new hash function for zero-knowledge proof systems,” in *Proc. USENIX Security*, 2021.
- [3] J. Groth, “On the size of pairing-based non-interactive arguments,” in *Proc. EUROCRYPT*, 2016, pp. 305–326.
- [4] A. Gabizon, Z. J. Williamson, and O. Ciobotaru, “PLONK: Permutations over Lagrange-bases for oecumenical noninteractive arguments of knowledge,” *Cryptology ePrint Archive*, Report 2019/953, 2019.
- [5] S. Bowe, J. Grigg, and D. Hopwood, “Recursive proof composition without a trusted setup,” *Cryptology ePrint Archive*, Report 2019/1021, 2019.
- [6] M. Yasuda, T. Shimoyama, J. Kogure, K. Yokoyama, and T. Izu, “Packed homomorphic encryption based on ideal lattices and its application to biometrics,” in *Proc. CANS*, 2013, pp. 55–74.
- [7] V. N. Boddeti, “Secure face matching using fully homomorphic encryption,” in *Proc. IEEE BTAS*, 2018.
- [8] J. Bringer, H. Chabanne, M. Favre, A. Patey, T. Schneider, and M. Zohner, “GSHADE: Faster privacy-preserving distance computation and biometric identification,” in *Proc. ACM Workshop on Information Hiding and Multimedia Security*, 2014.
- [9] R. Guo, H. Shi, D. Zheng, C. Jing, C. Zhuang, and Z. Wang, “Flexible and efficient blockchain-based ABE scheme with multi-authority for medical on demand in telemedicine system,” *IEEE Access*, vol. 7, pp. 88012–88025, 2019.
- [10] J. Lai, T. Wang, S. Zhang, Q. Yang, and S. C. Liew, “BioZero: An efficient and privacy-preserving decentralized biometric authentication protocol on open blockchain,” *arXiv preprint arXiv:2409.17509*, 2024.
- [11] X. Mao, X. Zhou, X. Zhao, and Y. Chen, “A ZKP-based anonymous biometric authentication scheme for e-health systems,” *PLOS ONE*, vol. 20, no. 6, e0324289, 2025.
- [12] D. Boneh, X. Boyen, and H. Shacham, “Short group signatures,” in *Proc. CRYPTO*, 2004, pp. 41–55.
- [13] J. Camenisch, M. Drijvers, and A. Lehmann, “Anonymous attestation using the strong Diffie-Hellman assumption revisited,” in *Proc. Trust and Trustworthy Computing*, 2016.